agentLUMEN

AGENTIC FLASHLIGHT CO

Agents handle routine operations
Humans govern strategy, exceptions, and high-stakes decisions

Build vs Buy Matrix

BUY (SaaS Tools)

Stripe/ Revolut	ShipStn	Zendesk
DataDog / PowerBI	DataDog / PowerBI	Xero

Commodity | PCI Handled | Fast

BUILD (Custom Moat)

Orchestration (RLM)	Context Graph	Transaction Firewall
Custom Agents	Pricing Engine	Security Observer

IP Moat | Decision Trace| Control

SaaS: **Tools behind a gateway (not autonomous agents)**

agentLUMEN

Why Agentic + What Drove the Physical Architecture

WHY AN AGENTIC FRAMEWORK?

Multi-agent, centrally governed
• Specialists coordinated centrally
• Keeps context without losing control

Commerce requires action, not answers
• Availability → checkout → pay → refund
• Transaction firewall + idempotency

Auditability by design
• Bi-temporal logs + decision provenance
• Security Observer is read-only evidence

CRITERIA THAT SHAPED THE PHYSICAL MODEL

Sovereignty + data residency
• PII + sensitive IP stay in colo
• Burst compute to cloud for elasticity/cost

Security + governance as built-in primitives
• Zero-trust posture (assume prompt injection)
• Policy-as-code (ABAC), step-up auth, HIL>$250

Compliance-ready evidence
• ISO 27001 / ISO 42001 / EU AI Act / PCI DSS
• Append-only decision trail for audits

Bottom line: agentLumen is a safe, auditable commerce agent architecture that scales via cloud without sacrificing sovereignty, IP protection, or payment-grade controls.

agentLUMEN

Logical ⇒ Physical Mapping

Business Driver	Architecture Decision	Physical Placement
Protect IP + secrets	Custom agents (not SaaS)	COLO
Audit trail for compliance	Bi-temporal context graph	COLO (PII zone)
Prevent AI misuse	Transaction Firewall	COLO (isolated)
Elastic customer traffic	Managed storefront + CDN	CLOUD
Reduce PCI scope	SaaS payments (Stripe)	EXTERNAL
Cost efficiency	Hybrid 70/30 split	COLO + CLOUD

BUILD (IP Moat)

Orchestrator (RLM)
Domain Agents
Transaction Firewall
Security Observer

DEPLOY (Managed)

Neo4j, Qdrant
PostgreSQL, Redis
API Gateway

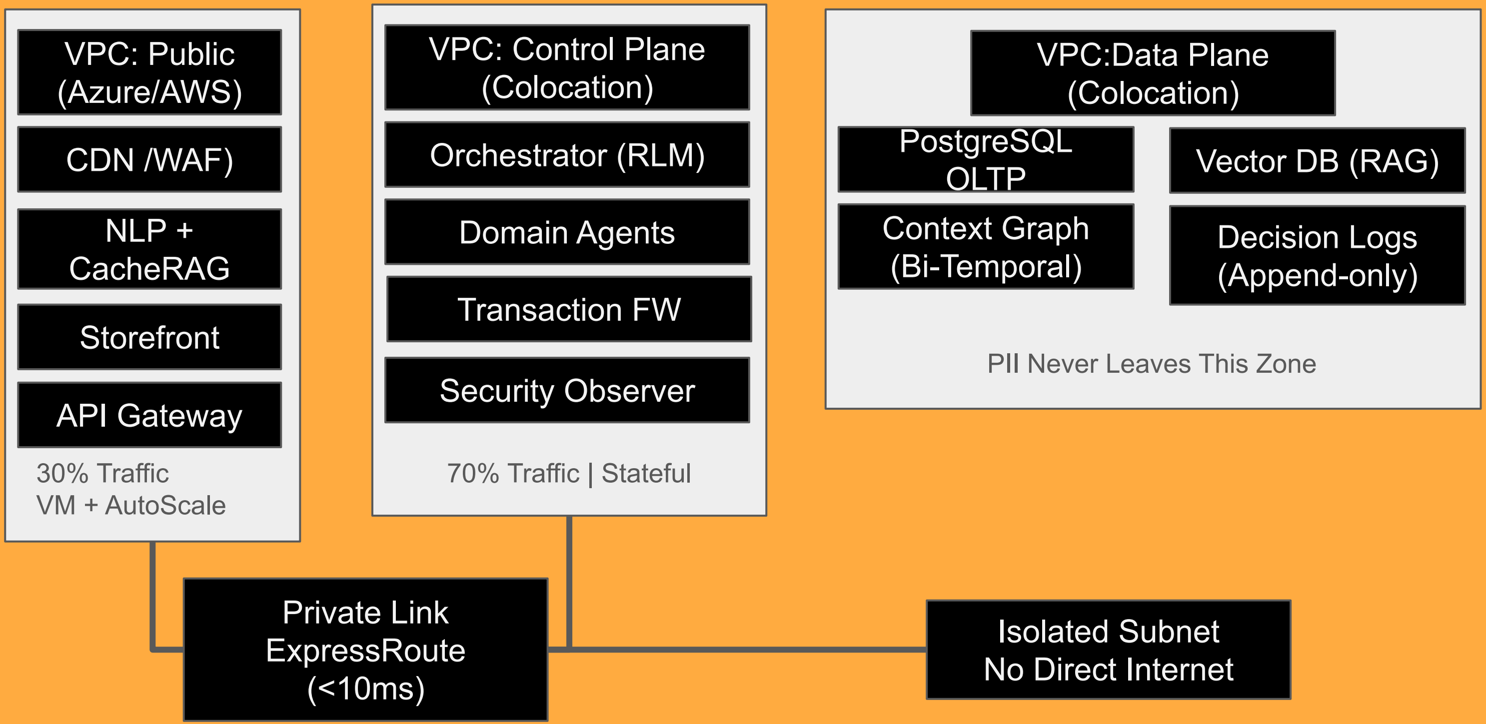
BUILD (IP Moat)

Stripe, ShipStation
Zendesk, Xero, Intercom
DataDog, Cloudflare

TOGAF

Business Architecture → Data/App/Tech Architecture → Implementation

Hybrid Deployment + Network Segmentation



Data Placement: Where everything lives

COLOCATION
Data Plane

PostgreSQL (OLTP)
- Orders, Customers
- Inventory, Products

Context Graph (Neo4j)
- Bi-temporal trace
- Decision provenance

Context Graph (Neo4j)
- Bi-temporal trace
- Decision provenance

PII + Sensitive

COLOCATION
Control Plane

Redis (Session 3h)
QDrant / Pinecone (Vec)
Neo4j (Context Graph)

Agent Runtime (GPU)
Orchestrator
Transactional FW

Security Observer

Compute + Memory

CLOUD (AZURE / AWS)
Analytics

BigQuery (OLAP)
- Aggregated only
- No PII
- RAGAS eval metrics

DataDog (SIEM/Monitoring)
- Logs Alerts
- Redacted Traces

PowerBI (Dashboards)
- Business KPIs

Analytics + Monitoring

RULE: **PII never leaves colo · Analytics gets aggregates only · Logs are redacted**

agentLUMEN

SECURITY + COMPLIANCE ARCHITECTURE

ZERO-TRUST AGENT MODEL

"Every agent assumed compromised"

- Microsegmented VPCs
- No agent-to-agent direct calls
- All comms via Orchestrator
- All comms via Orchestrator

WRITE SAFETY (TRANSACTION FW)

AGENTS Propose → Firewall Approve → SaaS Execute

- ABAC policy enforcement
- > $250 → Human approval
- Idempotency keys
- Step-up authentication

SECURITY OBSERVER (Read-Only)

ZERO write scopes

- Watches all tool calls
- MITRE ATLAS threat tagging
- Prompt injection detection
- Supply-chain anomaly alerts

Observer Recommends | Policy Router enforces

COMPLIANCE EVIDENCE

Bi-temporal Decision Trace

- What AI knew at decision time
- What evidence was retrieved
- What action was taken
- Policy version applied

Supports: ISO 42001, NIST AI RMF, EU AI Act,

RESILIENCE + IMPLEMENTATION

WHEN AI FAILS (Graceful Degradation)

"Every agent assumed compromised"

Agent Error → Auto-retry (3x) → Rule-based fallback → Assist mode → Human escalation

Low RAG confidence	→	Corrective RAG (broaden + verify)
Prompt injection	→	Block + alert Security Observer
High-risk decision	→	Route to Transaction Firewall HITL

IMPLEMENTATION PHASES

PHASE 1 (4wk)
Infra + Auth
3 VPCs + Link
Firewall MVP

PHASE 2 (4wk)
Integrations
RAG + Webhooks
RAGAS > 0.8

PHASE 3 (4wk)
Launch + Scale
Beta → Prod
< 5% human

TOGAF | **Architecture Roadmap aligned to Business Capability increments**

agentLUMEN

agentLUMEN

NEXT STEPS